

INCIDENT ANALYSIS REPORT

Apache Tomcat Serialized Payload RCE (CVE-2025-24813)

Event ID: 318

Prepared By:
Ashvin (0xAshvin)

Role:
Cybersecurity Analyst / Security Researcher

Date:
14 June 2026

Table of Contents

Official Incident Report	1
Event ID: 318	1
Rule Name: EventID:318 - SOC340 - Apache Tomcat Serialized Payload RCE	
(CVE-2025-24813)	1
Table of Contents	2
Alert	3
Detection	4
Verify	4
	Collect Data
	6
	Analysis
	9
	Examine The Traffic
	13
	Containment
	21
	Summary
	22
	Lesson Learned
	23
	Remediation Actions
	23
	Appendix
	24
	MITRE ATT&CK
	24
	Artifacts
	25

Alert

Security Alert: Suspicious Web Attack Detected

Just when we thought it was a quiet day, our monitoring systems have flagged a suspicious web attack on **Tomcat-Server02** (IP: 172.16.20.51).

The alert was triggered by our **SOC340** rule (EventID: 318) for **Apache Tomcat Serialized Payload RCE (CVE-2025-24813)**. This vulnerability stems from a path equivalence issue in how Tomcat handles partial PUT requests. Unfortunately, it gives remote, unauthenticated attackers a potential pathway to achieve remote code execution (RCE).

Full details here: -<https://nvd.nist.gov/vuln/detail/CVE-2024-24813>



EventID :	318
Event Time :	May 30, 2025, 06:19 PM
Rule :	SOC340 - Apache Tomcat Serialized Payload RCE (CVE-2025-24813)
Level :	Incident Response
Hostname :	Tomcat-Server02
Destination IP Address :	172.16.20.51
Source IP Address :	3.15.143.228
HTTP Request Method :	PUT
Requested URL :	/testattack.session
Uploaded File :	testattack.session
Content-Type :	application/java-serialized-object
Content-Length :	1006
Alert Trigger Reason :	Detected suspicious PUT request uploading a serialized Java session file (.session) to Tomcat default servlet, matching CVE-2025-24813 exploitation pattern.
L1 Note :	An attacker appears to have exploited a vulnerability by sending crafted partial HTTP PUT requests to upload a malicious serialized Java payload to a writable directory on the server. This activity is likely followed by unauthorized command execution. Alert assigned for in-depth analysis and containment.
Device Action :	Allowed

Key Observations:

- The device action was recorded as **"Allowed"**, meaning no blocking action was taken by the security appliance at the time of the activity.
- The server received a PUT request from the external IP **3.15.143.228**.
- We detected a suspicious PUT request attempting to upload a serialized Java session file (.session) to Tomcat's default servlet — a classic match for the CVE-2025-24813 exploitation pattern.

In simple terms, this critical vulnerability allows attackers to exploit unsafe deserialization in Tomcat's session persistence mechanism. By sending carefully crafted partial HTTP PUT requests, they can upload malicious serialized Java payloads into a writable directory on the server, which can then lead to unauthorized command execution.

Recommended Next Steps: Please treat this as a high-priority incident. The L1 analysis suggests the attacker successfully leveraged this vulnerability. Immediate investigation and containment on Tomcat-Server02 is strongly advised.

Detection

Verify

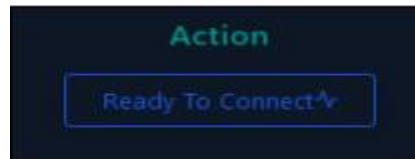
As the playbook suggests we can start investigating the alert by understanding why the alert was triggered

- A quick look at the rule name already gives us a clear hint — we're dealing with a precisely targeted detection for this specific threat.
- This vulnerability is a Time-of-check to Time-of-use (TOCTOU) Race Condition that occurs during JSP compilation in Apache Tomcat. It can allow remote code execution (RCE) on case-insensitive file systems under specific conditions.

Affected Versions:

- Apache Tomcat 11.0.0-M1 to 11.0.2
- Apache Tomcat 10.1.0-M1 to 10.1.34
- Apache Tomcat 9.0.0.M1 to 9.0.98
- How the Attack Works (Two Main Steps):
 - Arbitrary File Writing When session persistence is enabled, Tomcat neatly serializes all active user sessions before shutting down and brings them back on restart — so users don't even notice the reboot. But if HTTP PUT is enabled, attackers can sneak malicious files into the exact same directory where these serialized sessions live. Sneaky, right?
 - Insecure Deserialization Once the malicious file is planted in the session data directory, the attacker uses a crafted cookie to "wake up" a session. This forces Tomcat to deserialize the bad payload, opening the door to full remote code execution through the CVE-2025-24813 vulnerability.
- Traffic Details: The suspicious activity is happening between these two devices:
 - Source IP: 3.15.143[.]228 (external attacker)
 - Destination: 172.16.20.51 (Tomcat-Server02)
 - The device action was recorded as "Allowed", meaning nothing was blocked automatically. Immediate investigation and containment on Tomcat-Server02 is strongly recommended.

We can proceed with connecting to the host machine for further analysis. This can easily be done from the Endpoint Security tab by searching for the hostname or IP address and clicking the “Connect” button.



```
root@ip-172-31-7-40: /opt/tomcat/apache-tomcat-9.0.90/logs
File Edit View Search Terminal Help
root@ip-172-31-7-40:~# ps aux | grep tomcat
root      769   0.5   0.9 4527008 156760 ?        Ssl  23:23   0:05 /usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.file=/opt/tomcat/apache-tomcat-9.0.90/conf/logging.properties -Djava.util.logging.manager=org.apache.juli.ClassLoaderLogManager -Djava.awt.headless=true -Djava.security.egd=file:/dev/./urandom -Djdk.tls.ephemeralDHKeySize=2048 -Djava.protocol.handler.pkgs=org.apache.catalina.webresources -Dorg.apache.catalina.security.SecurityListener.UMASK=0027 -Xms512M -Xmx1024M -server -XX:+UseParallelGC -Dignore.endorsed.dirs= -classpath /opt/tomcat/apache-tomcat-9.0.90/bin/bootstrap.jar:/opt/tomcat/apache-tomcat-9.0.90/bin/tomcat-juli.jar -Dcatalina.base=/opt/tomcat/apache-tomcat-9.0.90 -Dcatalina.home=/opt/tomcat/apache-tomcat-9.0.90 -Djava.io.tmpdir=/opt/tomcat/apache-tomcat-9.0.90/temp org.apache.catalina.startup.Bootstrap start
root      2696   0.0   0.0   8160   2472 pts/0    S+   23:42   0:00 grep --color=auto tomcat
root@ip-172-31-7-40:~# cd /opt/tomcat/apache-tomcat-9.0.90/logs/
root@ip-172-31-7-40:/opt/tomcat/apache-tomcat-9.0.90/logs# cat
catalina.2025-05-30.log      localhost.2025-06-04.log
catalina.2025-06-04.log    localhost_access_log.2025-05-30.txt
catalina.out               localhost_access_log.2025-06-04.txt
host-manager.2025-05-30.log manager.2025-05-30.log
host-manager.2025-06-04.log manager.2025-06-04.log
localhost.2025-05-30.log
```

It is seen that the version of Apache Tomcat is vulnerable.

By checking the web.xml we can see that the default servlet is set to false, allowing write access to the servlet. Also “allowPartialPut” is true which means Tomcat will accept partial PUT requests using the Content-Range header. This allows attackers to upload files in chunks, bypassing certain upload restrictions or antivirus protections.

P.S.: This vulnerability can only be exploited if you change the default Tomcat settings. By default, the readonly option in Tomcat’s DefaultServlet is set to true, which blocks any write actions. The risk appears only if someone manually sets readonly to false, which allows files to be written through the servlet. To stay safe, always check and secure your server configuration settings.

```
<servlet>
  <servlet-name>default</servlet-name>
  <servlet-class>org.apache.catalina.servlets.DefaultServlet</servlet-class>
  <init-param>
    <param-name>debug</param-name>
    <param-value>0</param-value>
  </init-param>
  <init-param>
    <param-name>listings</param-name>
    <param-value>>false</param-value>
  </init-param>
  <init-param>
    <param-name>readonly</param-name>
    <param-value>>false</param-value>
  </init-param>
  <init-param>
    <param-name>allowPartialPut</param-name>
    <param-value>true</param-value>
  </init-param>
  <load-on-startup>1</load-on-startup>
</servlet>
```

A critical RCE (Remote Code Execution) vulnerability exists in Apache Tomcat, tracked as CVE-2025-24813, affecting systems that:

- Allow HTTP PUT requests.
- Have session persistence enabled.
- Include commons-collections-3.2.1.jar in their classpath.

This results in exploitable Java deserialization.

Collect Data

The next step in the playbook leads us to collect data and gather information about the relevant IP address.

Examining whether the IP address or domain has been linked to prior malicious activities and ownership of the IP address can provide insights into the current activity.

Hostname:	Tomcat-Server02
IP Address:	172.16.20.51
OS:	Ubuntu 20.04.02
Last Logon:	May, 30, 2025, 02:00 AM

When going through the technical details to check the affected versions, it's noted that host **Tomcat.Server02** with the IP address 172.16.20.51 is affected by this vulnerability.

We can check if the traffic is inbound or outbound from the log management system by filtering the IP address of the host. As seen in the log management traffic is inbound.

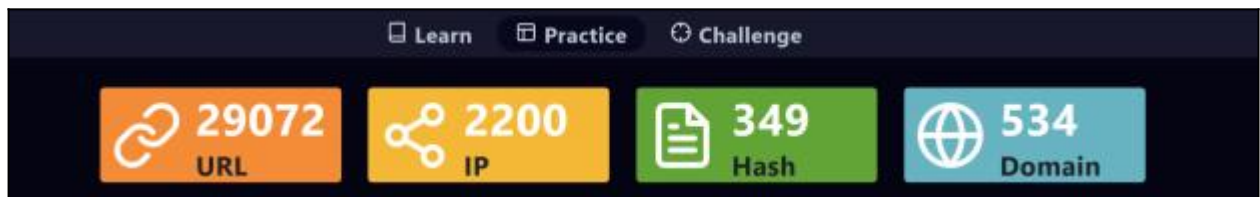


Basic Pro

Show Filter 172.16.20.51

DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
May, 30, 2025, 06:19 PM	Proxy	3.15.143.228	52345	172.16.20.51	8080	🔍
May, 30, 2025, 06:19 PM	Firewall	3.15.143.228	52345	172.16.20.51	8080	🔍
May, 30, 2025, 06:19 PM	Proxy	3.15.143.228	52345	172.16.20.51	8080	🔍
May, 30, 2025, 06:20 PM	Proxy	3.15.143.228	52345	172.16.20.51	8080	🔍
May, 30, 2025, 06:20 PM	Proxy	3.15.143.228	25432	172.16.20.51	8080	🔍
May, 30, 2025, 06:21 PM	Proxy	3.15.143.228	32432	172.16.20.51	8080	🔍
May, 31, 2025, 06:25 PM	Application	172.16.20.51	0	172.16.20.51	0	🔍

On the LetsDefend threat intel tab, you'll find a comprehensive database dedicated to cataloging maliciously used information, such as IP addresses, domains, and other indicators of compromise.



<https://app.letsdefend.io/threath-intelligence-feed>

Upon cross-referencing the destination IP address discovered in the log management system with the Threat Intel tab, it was determined that the address had been categorized as malicious.

Select Filters... Clear

Free text search	Date range	Search by data type	Search by data	Search by tag
3.15.143.228	Select Date	IP	Search	Search

Search

Minimize

DATE ↓	DATA TYPE	DATA	TAG	DATA SOURCE
May, 30, 2025, 02:29 AM	IP	3.15.143.228	CVE-2025-24811	OnlyHunt

By cross-referencing the IP address with threat intelligence platforms such as AbuseIP or VirusTotal, we found that the IP address has not been reported before.

Community Score

ⓘ No security vendor flagged this IP address as malicious

↻ Reanalyze ≈ Similar ∨ More ∨

3.15.143.228 (3.8.0.0/13)

AS 16509 (AMAZON-02)

US

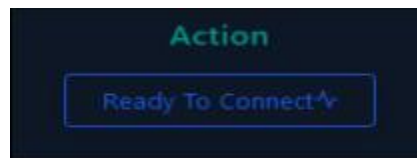
Last Analysis Date
7 months ago

DETECTION DETAILS RELATIONS COMMUNITY

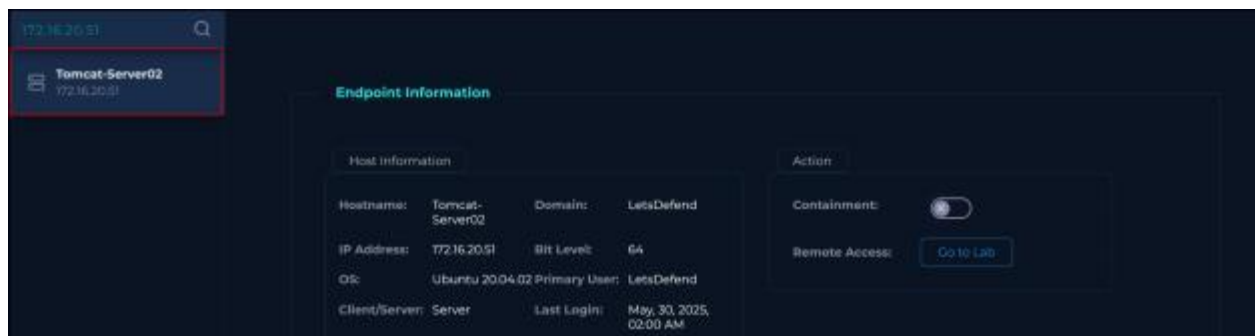
Based on the information provided by VirusTotal, the IP address has been flagged as benign by **all** antivirus engines. It was stated that “No security vendor flagged this IP address as malicious.”

Analysis

We can proceed with connecting to the host machine for further analysis. This can easily be done from the Endpoint Security tab by searching for the hostname or IP address and clicking the “Connect” button.



By searching the host's IP address on the Endpoint Security we can access the host and connect to it via the connect button.



The next step is investigating the access logs. Focusing on IP addresses, user-agents, paths, HTTP status codes and timestamps will help us identify any suspicious or malicious activity.

By analyzing these logs, we can gain insights into potential vulnerabilities or security breaches. Additionally, cross-referencing the information with known threat intelligence sources can provide us with a better understanding of the nature and severity of any identified threats.

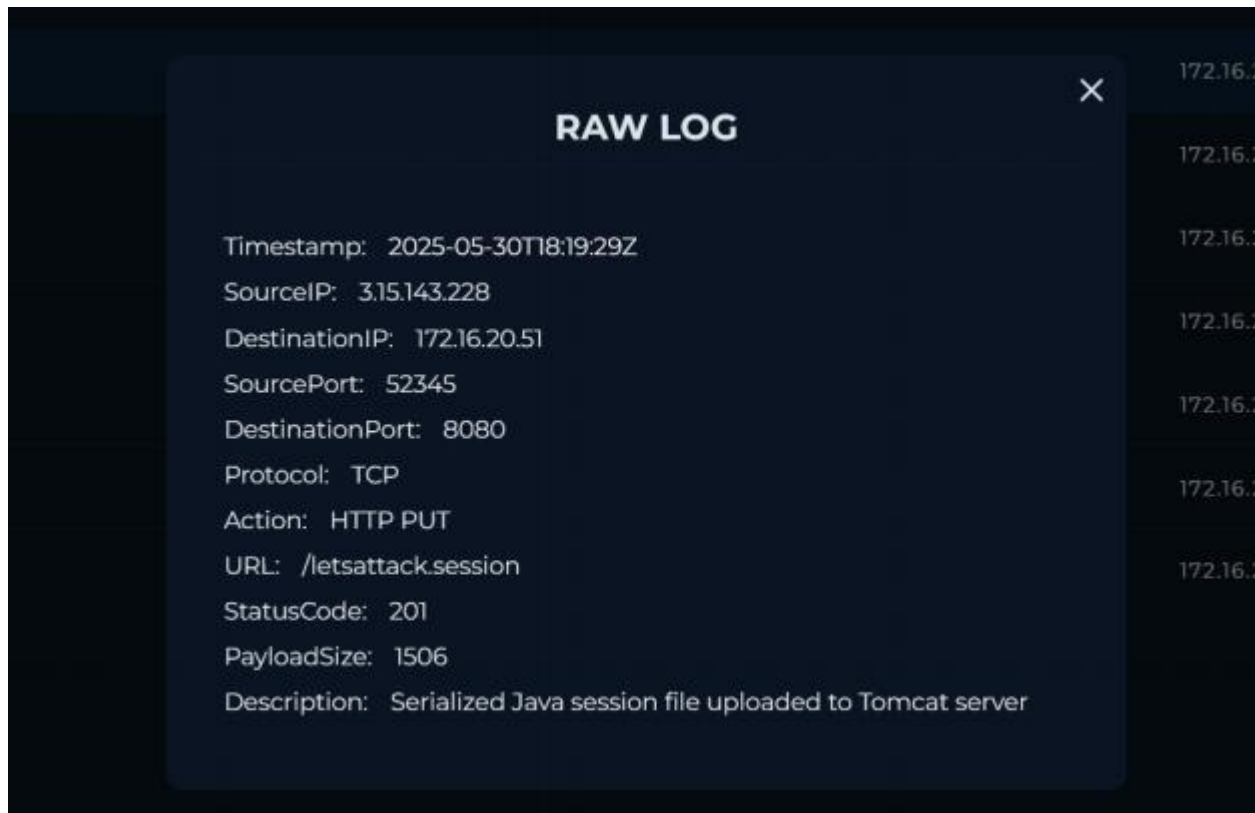
```
File Edit View Search Terminal Help
root@ip-172-31-7-40: /opt/tomcat/apache-tomcat-9.0.90/logs# ls
catalina.2025-05-30.log      localhost.2025-06-04.log
catalina.2025-06-04.log    localhost_access_log.2025-05-30.txt
catalina.out              localhost_access_log.2025-06-04.txt
host-manager.2025-05-30.log manager.2025-05-30.log
host-manager.2025-06-04.log manager.2025-06-04.log
localhost.2025-05-30.log
root@ip-172-31-7-40: /opt/tomcat/apache-tomcat-9.0.90/logs# cat localhost_access_log.2025-05-30.txt
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET / HTTP/1.1" 200 11428
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /tomcat.css HTTP/1.1" 200 5981
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /tomcat.svg HTTP/1.1" 200 68761
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /favicon.ico HTTP/1.1" 200 21630
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /bg-nav.png HTTP/1.1" 200 1401
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /asf-logo-wide.svg HTTP/1.1" 200 27530
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /bg-upper.png HTTP/1.1" 200 3103
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /bg-middle.png HTTP/1.1" 200 1918
15.143.228 - - [30/May/2025:18:18:42 +0000] "GET /bg-button.png HTTP/1.1" 200 713
15.143.228 - - [30/May/2025:18:19:29 +0000] "PUT /check.txt HTTP/1.1" 201 -
15.143.228 - - [30/May/2025:18:19:29 +0000] "PUT /letsattack.session HTTP/1.1" 201 -
15.143.228 - - [30/May/2025:18:19:31 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:19:47 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:19:47 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:19:48 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:19:57 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:19:58 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:19:59 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:20:25 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:20:25 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:20:26 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:20:39 +0000] "GET /id.txt HTTP/1.1" 200 44
15.143.228 - - [30/May/2025:18:21:00 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:21:00 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:21:01 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:21:49 +0000] "GET /passwd.txt HTTP/1.1" 200 3276
15.143.228 - - [30/May/2025:18:22:50 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:22:50 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:22:51 +0000] "GET /hello-servlet HTTP/1.1" 500 2901
15.143.228 - - [30/May/2025:18:23:11 +0000] "PUT /check.txt HTTP/1.1" 204 -
15.143.228 - - [30/May/2025:18:23:11 +0000] "PUT /letsattack.session HTTP/1.1" 204 -
```

Examine The Traffic

The third step of the playbook involves examining the traffic. This step is crucial in identifying any suspicious or malicious activities and understanding the overall network behavior. Additionally, examining the traffic can provide valuable information for further investigation and potential security enhancements.

Considering that this attack involves an exploit targeting the host named Tomcat-Server02, we can use the time when the alert was triggered as a reference point for analysis. Filtering the host named Tomcat-Server02 IP address in log management allows us to view the logs.

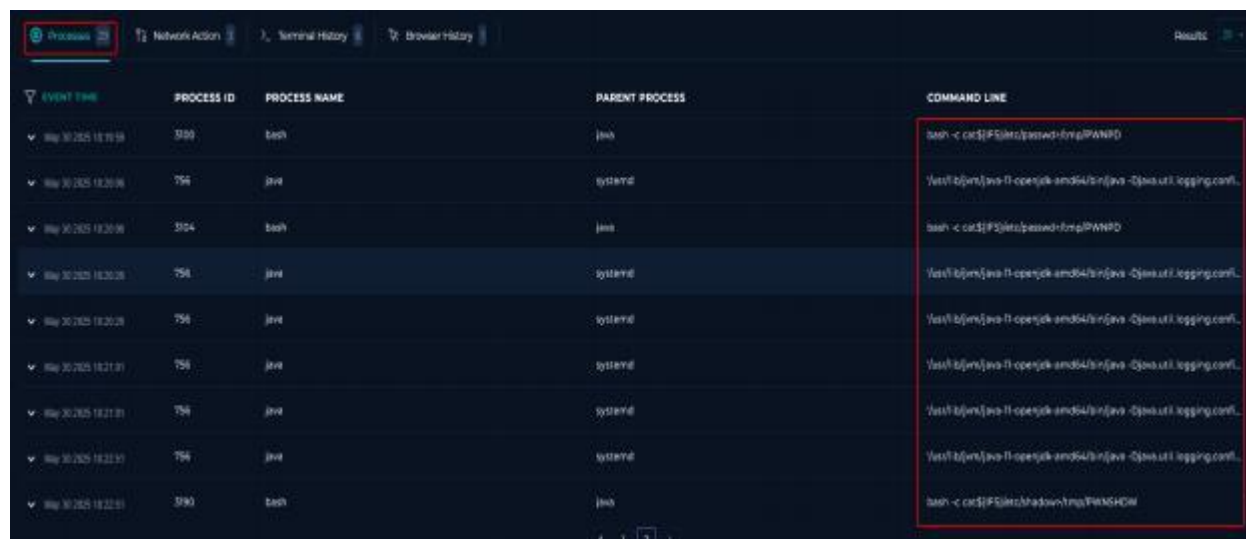
Firewall logs for the date of February 22th are available. These logs are essential for monitoring and analyzing network traffic and security events on that specific date.



1. Initial Reconnaissance and Exploit Upload:

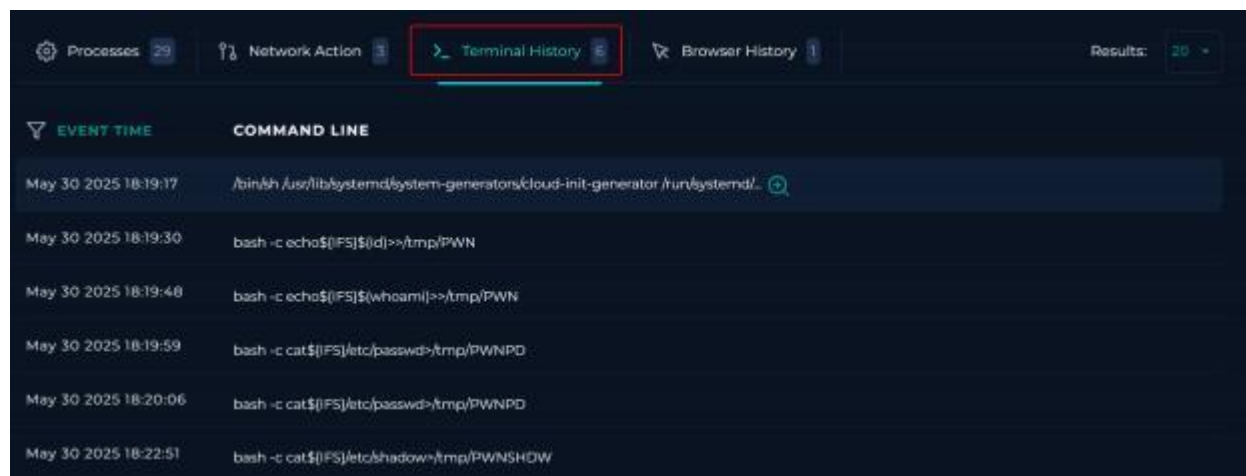
The attacker sent an HTTP PUT request to the Tomcat server (172.16.20.51) from the external IP (3.15.143.228), uploading a malicious serialized Java session file (e.g., /letsattack.session). This file contained a crafted payload designed to execute arbitrary code upon deserialization. The successful HTTP 201 response indicated that the file was accepted and stored by the server.

Based on our analysis, we have confirmed that the traffic is **malicious**.



EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
May 30 2025 18:19:59	590	bash	java	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD
May 30 2025 18:20:06	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:20:06	594	bash	java	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD
May 30 2025 18:20:06	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:20:06	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:21:01	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:21:01	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:22:51	756	java	systemd	/usr/lib/jvm/java-11-openjdk-amd64/bin/java -Djava.util.logging.config.
May 30 2025 18:22:51	590	bash	java	bash -c cat\$(IFS)/etc/shadow>/tmp/PWNHSHDW

By checking the terminal history we can also see the malicious commands.



EVENT TIME	COMMAND LINE
May 30 2025 18:19:17	/bin/sh /usr/lib/systemd/system-generators/cloud-init-generator /run/systemd/.
May 30 2025 18:19:30	bash -c echo\$(IFS)\$(id)>>/tmp/PWN
May 30 2025 18:19:48	bash -c echo\$(IFS)\$(whoami)>>/tmp/PWN
May 30 2025 18:19:59	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD
May 30 2025 18:20:06	bash -c cat\$(IFS)/etc/passwd>/tmp/PWNPD
May 30 2025 18:22:51	bash -c cat\$(IFS)/etc/shadow>/tmp/PWNHSHDW

The identified attack types are **Command Injection** and **Other**, as the exploitation enables arbitrary command execution through a deserialization vulnerability in Apache Tomcat's default servlet.

The **CVE-2025-24813** vulnerability allows an attacker to upload a malicious serialized Java session file. When the server deserializes this file, arbitrary code is executed with the privileges of the Tomcat process. This results in **Remote Code Execution (RCE)**, enabling the attacker to execute system commands, modify files, and potentially escalate privileges or move laterally within the network.

Threat Intelligence and Investigation Findings

Upon examining the relevant web traffic, it was observed that the attacker's IP address is listed as an **Indicator of Compromise (IOC)** in global threat intelligence sources. Furthermore, no evidence was identified suggesting that the activity was conducted for testing or authorized purposes.

The IP address and hostname associated with the affected system were searched across email records received during the specified timeframe. However, no evidence of planned maintenance, authorized testing, or legitimate activity was identified during the investigation.

Therefore, the answer for this playbook step is **"Not Planned."**

Traffic Direction Analysis

The next step in the playbook involves determining the direction of the traffic.

To identify the traffic direction, all logs collected from security products on the log management platform will be reviewed. The **alert creation time** serves as a key reference point for correlating events and conducting a comprehensive investigation of the incident.



Show Filter						
Basic Pro						
172.16.20.51						
DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
May, 30, 2025, 06:19 PM	Proxy	3.15.143.228	52345	172.16.20.51	8080	🔍

In the log management page, all malicious traffic originated from the Internet and targeted the Company Network.

The source address was **3.15.143.[.]228**, while the destination address was **172.16.20.51**. Therefore, the traffic direction for this playbook step is **Internet → Company Network**.

Attack Success Assessment

The next step in the playbook is to determine whether the attack was successful by analyzing the impact of the attacker's actions and evaluating whether the intended objectives were achieved.

Yes, the attack was successful due to multiple factors that enabled exploitation of **CVE-2025-24813** and resulted in **Remote Code Execution (RCE)** on the target Apache Tomcat server.

Vulnerable Tomcat Version

The target system was running a vulnerable version of Apache Tomcat (versions **9.0.0-M1–9.0.98**, **10.1.0-M1–10.1.34**, or **11.0.0-M1–11.0.2**) affected by **CVE-2025-24813**.

Default Servlet Write Enabled

The Tomcat default servlet had write permissions enabled, allowing the attacker to upload arbitrary files to the server's web application directory.

Serialized Payload Upload

The attacker exploited the write-enabled servlet by uploading a malicious Java session file (**.session**) using an HTTP **PUT** request. The file contained a crafted serialized payload designed to trigger code execution during deserialization.

Deserialization Trigger

After uploading the malicious session file, the attacker issued an HTTP **GET** request to trigger deserialization. This process executed arbitrary code within the Tomcat server's context.

Command Execution

Following successful exploitation, the attacker executed system commands on the server. This activity was evidenced by the creation and modification of files in temporary directories (e.g., **/tmp**) and the web application directory.

Information Exfiltration

The attacker exfiltrated sensitive information, including the contents of **/etc/passwd**, by copying the data into web-accessible files such as **id.txt** and **passwd.txt**, which were later retrieved via HTTP requests.

Summary

In summary, the successful exploitation of **CVE-2025-24813** resulted from a combination of a vulnerable Tomcat version, insecure servlet configuration, malicious payload upload, deserialization-based execution, command execution, and information exfiltration. This incident highlights the importance of maintaining updated software, implementing secure configurations, and continuously monitoring for suspicious activity.

Analyzing system responses also helps determine whether malicious implants or persistence mechanisms exist on the compromised host, providing additional insight into the extent of the compromise.

As the next investigative step, logs should be filtered for the host **172.16.20.51** to identify additional malicious activity and determine the overall scope of the incident.

Show Filter		172.16.20.51				
DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
May, 30, 2025, 06:19 PM	Binary	3.15.143.228	67145	172.16.20.51	8080	🔍
May, 30, 2025, 06:19 PM				172.16.20.51	8080	🔍
May, 30, 2025, 06:19 PM				172.16.20.51	8080	🔍
May, 30, 2025, 06:20 PM				172.16.20.51	8080	🔍
May, 30, 2025, 06:20 PM				172.16.20.51	8080	🔍
May, 30, 2025, 06:21 PM				172.16.20.51	8080	🔍
May, 31, 2025, 06:25 PM				172.16.20.51	0	🔍

RAW LOG

Timestamp: 2025-05-30T18:21:49Z

SourceIP: 3.15.143.228

HTTPMethod: GET

URL: /passwd.txt

HTTPVersion: HTTP/1.1

StatusCode: 200

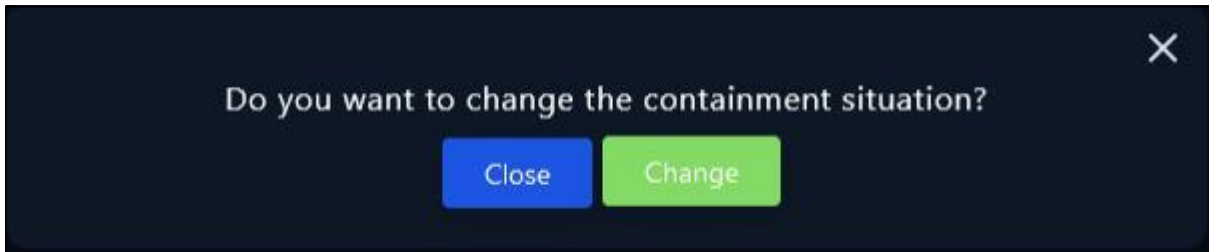
ResponseSize: 3276

Description: Successful retrieval of passwd.txt file

Based on the HTTP response code of 200, it appears that the request to **172.16.20.51** was successful. Through log analysis, we have confirmed that **the attack was successful**.

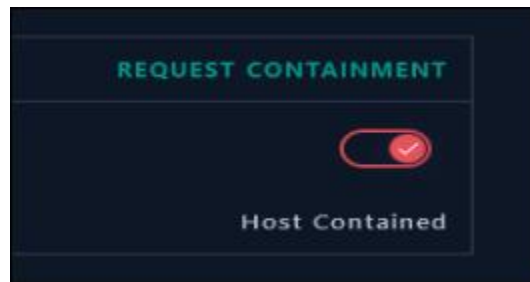
Containment

Based on the information gathered during the investigation, it is highly likely that the system has been compromised. To prevent further data loss or unauthorized access, it is recommended to isolate the system from the network immediately.



Isolation of the host can be made from the endpoint security tab.

Hostname	Tomcat-Server02
IP Address	172.16.20.51



After the containment, we can close the alert from the investigation channel.

Summary

The alert report identified a suspicious web attack targeting **Tomcat-Server02** (IP: **172.16.20.51**) associated with **SOC340 – Apache Tomcat Serialized Payload RCE (CVE-2025-24813)**, a vulnerability that allows threat actors to gain unauthorized access and execute arbitrary code.

Analysis showed that the device action was marked as **"Allowed,"** indicating that no security control blocked the attack. The source IP **3.15.143[.]228** issued an HTTP **PUT** request attempting to exploit the vulnerability. Threat intelligence platforms, including **LetsDefend** and **VirusTotal**, linked the IP address to malicious activity.

Traffic analysis confirmed a successful exploitation pattern leveraging Tomcat's **write-enabled default servlet** and **partial PUT support**. The attacker uploaded a malicious serialized payload via an HTTP PUT request and triggered it using a subsequent GET request, resulting in **Remote Code Execution (RCE)**. Evidence of compromise included file creation and modification in sensitive directories, along with access attempts to files such as **id.txt** and **passwd.txt**.

The vulnerability exists because a write-enabled default servlet combined with partial PUT support allows unauthenticated users to upload and execute malicious payloads. The use of **file-based session persistence** in default locations further facilitates exploitation.

This incident highlights the need for immediate remediation, including upgrading Apache Tomcat to patched versions (**9.0.99+**, **10.1.35+**, or **11.0.3+**), disabling write permissions on the default servlet, and restricting partial PUT requests. Continuous monitoring for suspicious PUT requests, **.session** file uploads, and abnormal **HTTP 500** responses is essential for early detection.

Given the high likelihood of compromise, containment measures are recommended to prevent lateral movement. Following a thorough investigation and remediation, the alert can be closed accordingly.

Lesson Learned

- Timely threat intelligence plays a critical role in identifying emerging vulnerabilities and exploits, enabling organizations to respond proactively and reduce security risks before they escalate.
- Continuous monitoring of specific Indicators of Compromise (IOCs) enhances the detection of potential threats; however, IOC-based monitoring should be complemented by deeper analysis and contextual investigation to ensure comprehensive threat detection.
- Effective threat hunting and detailed forensic investigations are essential for determining the scope of an incident, understanding attacker activity, and assessing the potential impact on organizational assets and operations.
- Maintaining awareness of newly disclosed vulnerabilities and promptly applying relevant patches or mitigations are fundamental practices for preserving system integrity and strengthening the overall security posture. After all, attackers rarely wait for maintenance windows.

Remediation Actions

- Apply the latest security patches and updates to remediate the **CVE-2025-24813** vulnerability on **Tomcat-Server02**, thereby eliminating the identified attack vector and strengthening the server's security posture.
- Restrict external network access to **Tomcat-Server02** and any publicly accessible server instances until the required upgrades and validation activities have been successfully completed. A temporary inconvenience today is far preferable to an incident report tomorrow.
- Isolate the compromised system from the network immediately to prevent lateral movement and unauthorized access to other organizational resources, ensuring containment while remediation efforts are underway.

Artifacts

IOC TYPE	VALUE
IPv4	3.15.143[.]228
URI	172.16.20.51
File	/letsattack.session
File	/hello-servlet
File	/check.txt
File	/passwd.txt
File	/id.txt